

A Unified Architecture for Risk Reasoning: Bridging Ontologies, Theorem Proving, and Model Checking

Anonymous authors

Formal risk analysis for complex systems is currently fragmented across heterogeneous standard models – including fault trees, attack trees, and Bayesian networks – each with distinct semantics and verification techniques. This fragmentation hinders interoperability, compositional reasoning, and the integration of formal guarantees in complex and interacting systems. In this short research paper, we design a high-level framework for a unified architectural approach to safety-(cyber)security risk verification based on three pillars: (i) *ontology-grounded semantics* ensuring a shared conceptual foundation, (ii) *deductive verification* via interactive theorem proving, enabling compositional and explainable reasoning, and (iii) *integration with model checking techniques* for automation of (quantitative) analysis. The key insight is the integration of deductive and algorithmic reasoning about risk, where model checking is embedded as a trusted oracle within proof development: interoperability is guaranteed via an ontology that builds shared semantics. In this architecture, classical risk models emerge as fragments of a unified language, rather than being treated as stand-alone artefacts. This yields a semantically robust, hybrid risk reasoning workflow, combining proof and automation. We argue that this approach provides a principled foundation for unified, rigorous, explainable, and scalable safety-(cyber)security risk analysis of complex interacting systems.

1 Introduction

Modern risk analysis for complex systems operates at the intersection of safety, (cyber)security, and increasingly, their interaction [24]. Cyber-physical infrastructures, distributed services, and AI-enabled systems exhibit tightly coupled behaviours in which faults, attacks, and cascading effects cannot be analysed in isolation. As a result, risk reasoning must account for heterogeneous phenomena – ranging from accidental failures (*safety*) to adversarial actions (*security*) – within a unified perspective [33].

Recent incidents highlight this interplay. In the Oldsmar water treatment facility attack [7], an adversary gained remote access and attempted to manipulate levels of chemicals in the water, illustrating how a security breach can directly induce safety-critical consequences. Conversely, the CrowdStrike outage [9] showed how a non-adversarial software fault can propagate globally, disrupting critical services and infrastructures. Such events demonstrate that failures and attacks are not isolated phenomena, but interact and propagate across system layers, requiring integrated reasoning about safety and security.

Problem statement. In practice, however, risk modelling remains fundamentally fragmented. Widely adopted formalisms such as fault trees (FTs) [34, 29], attack trees (ATs) [18, 32], and Bayesian networks (BNs) [28, 15] each capture specific aspects of system behaviour – respectively failure propagation, adversarial strategies, and probabilistic dependencies – but differ in syntax, semantics, and associated analysis techniques. As a consequence, analyses are difficult to combine, results are hard to compare, and interoperability across tools and domains remains limited. This limitation is particularly acute in interacting systems, where safety and security concerns are intrinsically coupled. Existing approaches typically rely on loosely coupling heterogeneous models or translating between them, leading to ad hoc integration and limited formal guarantees [24]. A similar divide exists at the level of verification techniques. *Deductive approaches*, such as theorem proving, support expressive, compositional, and

explainable reasoning, but require substantial manual effort. In contrast, *model checking* provides automated and exhaustive analysis, including quantitative evaluation, but is restricted to specific modelling formalisms. Despite their complementary strengths, these paradigms are yet to be integrated within a single reasoning framework for risk.

Our proposal. In this short paper, we propose a *unified architectural approach* to safety-(cyber)security risk verification that addresses both forms of fragmentation. Our approach is based on three pillars:

1. **Ontology-grounded semantics**, providing a shared conceptual foundation for risk-related notions;
2. **Deductive verification**, via theorem proving, enabling compositional and explainable reasoning;
3. **Model checking**, enabling automated (quantitative) analysis within this unified framework.

The central idea is to integrate deductive and algorithmic reasoning within a *semantically unified setting*, leveraging (risk) ontologies. This allows us to treat model checking as an embedded *trusted oracle* within proof development: when a proof obligation falls into an automatically analysable fragment, it is compiled into a model checking instance and discharged algorithmically, with results re-integrated into the proof. The underlying ontology ensures that all components share a common semantics, providing interoperability by construction. A key consequence of this design is that classical risk models such as FTs, ATs, and BNs are not treated as external artefacts, but instead emerge as fragments of a unified language.

Our contribution. The contribution of this paper lies in *articulating and systematising this architectural vision*: i.e., we identify and assemble the necessary components into a coherent architecture. This architecture is informed by existing formal and tool-oriented developments, including ontology engineering (e.g., foundational and domain ontologies), interactive theorem proving, and model checking techniques for established risk models.

In summary. We propose a *unified architecture for safety–security risk verification* that integrates *ontology-grounded semantics* with *deductive reasoning* and *model checking*. Our approach reinterprets heterogeneous risk models as fragments within a single semantically coherent and verification-aware framework.

We argue that this approach provides a principled foundation for unified, rigorous, explainable, and scalable safety-(cyber)security risk analysis of complex interacting systems, in line with the needs of modern non-trivial environments.

2 A Unified Framework for Risk Reasoning

Fig. 1 summarises the architectural vision developed in this paper. At the core lies an ontological layer (in **yellow**), which provides common meaning to the entities manipulated by the framework, i.e., it grounds shared risk notions semantically. On top of this layer, deductive reasoning is performed interactively in a theorem prover via a custom domain-specific language (in **light blue**). Whenever a proof obligation falls into a fragment that admits effective automated analysis, it is translated into a model checking instance, solved externally, and the result is re-integrated into the proof (in **pink**). In this way, semantics, deduction, and automation are coordinated within a single verification architecture for risk reasoning.

2.1 Semantic Layer: Foundational and Domain Ontologies

The architecture is grounded in an explicit semantic layer, whose role is to provide a shared and well-founded interpretation of the concepts involved in risk reasoning that both the deductive and algorithmic

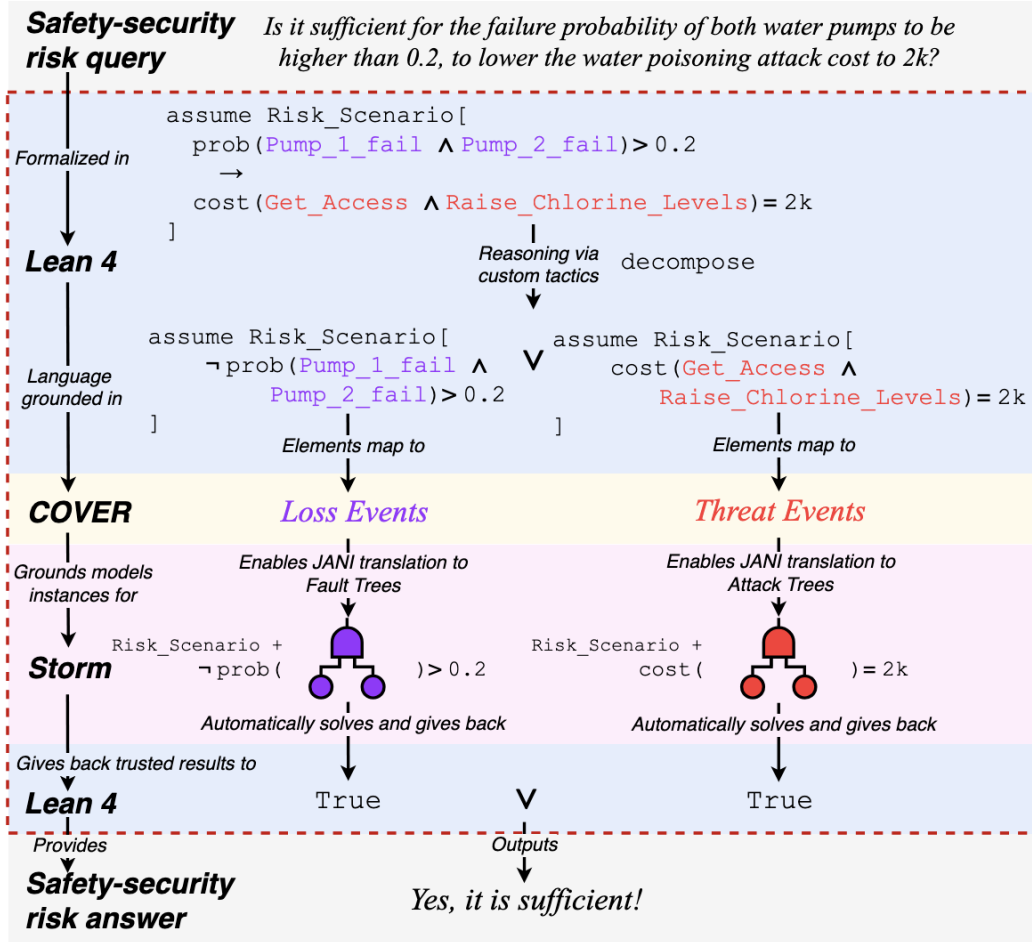


Figure 1: Overview of the proposed architecture. Ontology-grounded concepts provide a shared semantic layer; deductive reasoning is carried out in Lean via a domain-specific language for risk; automatically analysable proof obligations are compiled to standard model checking formalisms and discharged by an external engine (here, the Storm model checker); results are then re-integrated into the proof workflow.

layers can use to guarantee interoperability. At its core, we propose a stratified ontological approach, combining a *foundational ontology* with a *domain-specific ontology* for risk. The *Common Ontology of Value and Risk* (COVER) [30] provides a domain-level conceptualisation of risk grounded in *UFO* [12], a well-established foundational ontology. UFO offers a principled account of core ontological categories such as *objects*, *events*, *relations*, and *dispositions*, and has been extensively developed and applied in conceptual modelling and ontology engineering, e.g., [10, 11, 16].

Building on this foundation, COVER introduces a domain-independent conceptualisation of risk that captures key notions such as *value*, *threat/loss events*, *likelihood*, and *propagation*. Its design is informed by, and systematically aligned with, established definitions of risk in the broader literature on risk analysis and management, e.g., [14]. In particular, it reflects widely accepted views of risk as involving uncertain events affecting valued assets, together with mechanisms of dependency and propagation. Importantly, COVER has undergone validation through comparison with existing risk frameworks and has already been used to support the construction of formal models for risk quantification and propagation

[8, 20]. This provides evidence that the ontology is not only conceptually well-founded, but also practically suitable as a semantic backbone for formal reasoning.

For the purposes of this proposal, the adoption of UFO and COVER ensures that the entities manipulated by the framework are interpreted within a coherent and well-founded semantic structure. This, in turn, enables interoperability by construction, as different modelling paradigms are grounded in a shared conceptual vocabulary rather than aligned post hoc through translations. This vision is concretely supported by literature that already explores – and leverages – COVER to give semantical clarity [26, 27] or extended expressiveness [20] to fault and attack tree-based formalisms.

2.2 Deductive Layer: Interactive Theorem Proving

On top of the semantic layer, the architecture proposes a deductive reasoning layer based on interactive theorem proving. In this setting, risk-related statements are expressed in a domain-specific language – easy to understand for engineers, but rooted in formal logic – and reasoning proceeds via the construction of machine-checkable proofs. These proofs will employ *primitives that build on top of the ontologically sound vocabulary* adopted from COVER constructs.

We propose a modern theorem prover such as Lean 4 [19] as the core environment for this layer. Lean has gained significant traction in recent years as a platform for formal mathematics and verified reasoning, supported by a large and active ecosystem (e.g., the `mathlib` [1] and `cslib` [3] libraries). Its expressiveness and programmability make it particularly suitable for encoding domain-specific reasoning patterns. Notably, *custom proof tactics* [19] – commonly integrated in Lean – can be implemented directly within the system, enabling the development of tailored reasoning procedures for risk-related concepts such as *propagation*, *decomposition*, or *dependency*. Beyond its technical capabilities, Lean has demonstrated its effectiveness in large-scale formalisation efforts. Prominent examples include the formalisation of advanced mathematical results by researchers such as Terence Tao [5], highlighting the feasibility of encoding complex and nuanced reasoning in a machine-checkable form.

In the context of this work, Lean plays a dual role. First, it provides the environment in which semantically grounded reasoning is carried out, allowing proofs about risk to be constructed, structured, and checked. Second, it serves as a platform to enable automated reasoning within the algorithmic layer: proof obligations derived within Lean can be analysed, transformed, and, when appropriate, delegated to external model checking tools. Additionally, Lean positions itself as a sensible technology for ontology-based reasoning, as testified by ongoing efforts to encode UFO’s axioms in a machine-checkable form¹. Thus, the deductive layer provides compositionality, abstraction, and explainability, forming the entry-point of the proposed architecture and enabling the construction of arguments about safety-(cyber)security risks.

2.3 Algorithmic Layer: Model Checking of Risk Fragments

Complementing the deductive layer, the architecture incorporates an algorithmic layer for automated analysis. This layer targets fragments of the reasoning process that can be effectively analysed using existing techniques, in particular model checking.

We focus on standard risk formalisms – i.e., FTs, ATs and BNs – together with a model checking back-end capable of quantitative evaluation: the Storm model checker [13]. The key design choice is that these models are not treated as standalone artefacts, but as analysable fragments that can be extracted from the broader reasoning context. This extraction is made possible by the semantic clarity

¹<https://github.com/smnicoletti/lean-ufo/tree/main>

provided by COVER: constructs in the domain-specific language embedded in Lean can be mapped to appropriate counterparts in these established risk models. For instance, proof obligations involving combinations of COVER’s *Loss Events* can be naturally interpreted as fault tree structures, which capture failure propagation patterns (see Fig. 1). When such a fragment (i.e., a proof subgoal) is identified, it can be compiled into a suitable model checking representation and analysed automatically, leveraging existing algorithms in risk analysis [4]. This enables the computation of quantitative properties – such as *failure probabilities*, *likelihoods* of events, or attack-related *metrics* (e.g., attack time, cost) [17] – using mature technologies and tool support, without abandoning the surrounding deductive framework.

In this context, the field of *probabilistic model checking* [2] provides a particularly suitable foundation. The Storm model checker [13] offers state-of-the-art support for the analysis of stochastic systems and already provides native support for several relevant formalisms, including FTs and BNs [4, 31]. Moreover, the use of standard model exchange formats (such as JANI [6]) enables white-box integration with other tool pipelines for automation. This layer is further supported by prior work in the literature on domain-specific logics and model checking algorithms tailored to these risk models. In particular, logics such as *BFL* [21] and *PFL* [22] for FTs, *ATM* [23] for ATs, and *BayesL* [25] for BNs provide structured languages for expressing and analysing queries directly at the level of these models.

Building on top of this work, our proposal aims at re-integrating efficient technologies and languages for risk management as the automation backbone of our unified framework.

3 Discussion and Outlook

The novel architecture presented in this paper is intended as a unifying perspective rather than a fully realised toolchain. Its purpose is to identify and organise the key ingredients required for semantically coherent and verification-aware risk reasoning, and to show how they can be made to interact within a single framework.

Discussion. A central aspect of this vision is the explicit role of ontology. By grounding risk-related notions in a shared conceptual foundation, the approach avoids the need for ad hoc alignments between heterogeneous technologies. Instead, interoperability is achieved by construction, as all artefacts are interpreted within the same semantic layer. This is particularly relevant in settings where safety and security concerns interact, and where different modelling traditions must be combined without loss of meaning. The integration of deductive and algorithmic reasoning further strengthens this perspective. Treating model checking as a trusted oracle within proof development allows these two modes of reasoning to be combined without collapsing their respective strengths. While a full realisation of this architecture is beyond the scope of the present work, these ingredients already suggest a concrete path towards implementation via Lean 4 and the Storm model checker. In particular, ongoing efforts to formalise ontological foundations within the Lean theorem prover, together with existing tool support for model checking of risk models, indicate that the proposed integration is practically attainable.

Outlook. Future work will focus on making the architecture more concrete along several dimensions, including the formalisation of the underlying ontology in a theorem-proving environment, the design of proof-oriented languages for risk reasoning, and the development of tool pipelines connecting deductive reasoning with the model checking back-end. Another important direction is the systematic study of the expressiveness and limitations of the fragments corresponding to classical risk models within the unified framework. More broadly, we see this work as the first, foundational step of a shift towards semantically grounded and verification-aware approaches to risk analysis, in which heterogeneous models, formal reasoning, and automated techniques are integrated within a single conceptual and technical ecosystem.

References

- [1] Anne Baanen, Matthew Robert Ballard, Johan Commelin, Bryan Gin-ge Chen, Michael Rothgang & Damiano Testa (2025): *Growing Mathlib: maintenance of a large scale mathematical library*. In: *International Conference on Intelligent Computer Mathematics*, Springer, pp. 51–70.
- [2] Christel Baier & Joost-Pieter Katoen (2008): *Principles of model checking*. MIT press.
- [3] Clark Barrett, Swarat Chaudhuri, Fabrizio Montesi, Jim Grundy, Pushmeet Kohli, Leonardo de Moura, Alexandre Rademaker & Sorrachai Yingchareonthawornchai (2026): *CSLib: The Lean Computer Science Library*. *arXiv preprint arXiv:2602.04846*.
- [4] Daniel Basgöze, Matthias Volk, Joost-Pieter Katoen, Shahid Khan & Marielle Stoelinga (2022): *BDDs strike back: efficient analysis of static and dynamic fault trees*. In: *NASA Formal Methods Symposium*, Springer, pp. 713–732.
- [5] José Ramón Brox López, Terence Tao, Matthew Bolan, Joachim Breitner, Nicholas Carlini, Mario Carneiro, Floris van Doorn, Martin Dvorak, Andrés Goens, Aaron Hill et al. (2025): *The Equational Theories Project: Advancing Collaborative Mathematical Research at Scale*.
- [6] Carlos E Budde, Christian Dehnert, Ernst Moritz Hahn, Arnd Hartmanns, Sebastian Junges & Andrea Turrini (2017): *JANI: quantitative model and tool interaction*. In: *International Conference on Tools and Algorithms for the Construction and Analysis of Systems*, Springer, pp. 151–168.
- [7] James Cervini, Aviel Rubin & Lanier Watkins (2022): *Don’t drink the cyber: Extrapolating the possibilities of Oldsmar’s water treatment cyberattack*. In: *International conference on cyber warfare and security*, 17, Academic Conferences International Limited, pp. 19–25.
- [8] Mattia Fumagalli, Gal Engelberg, Tiago Prince Sales, Ítalo Oliveira, Dan Klein, Pnina Soffer, Riccardo Baratella & Giancarlo Guizzardi (2023): *On the semantics of risk propagation*. In: *International Conference on Research Challenges in Information Science*, Springer, pp. 69–86.
- [9] A Shaji George (2024): *When trust fails: Examining systemic risk in the digital economy from the 2024 crowdstrike outage*. *Partners Universal Multidisciplinary Research Journal* 1(2), pp. 134–152.
- [10] Giancarlo Guizzardi & Gerd Wagner (2004): *Towards ontological foundations for agent modelling concepts using the unified foundational ontology (UFO)*. In: *International Bi-Conference Workshop on Agent-Oriented Information Systems*, Springer, pp. 110–124.
- [11] Giancarlo Guizzardi & Gerd Wagner (2010): *Using the unified foundational ontology (UFO) as a foundation for general conceptual modeling languages*. In: *Theory and applications of ontology: computer applications*, Springer, pp. 175–196.
- [12] Giancarlo Guizzardi et al. (2022): *UFO: Unified foundational ontology*. *Appl. Ont.* 17(1).
- [13] Christian Hensel, Sebastian Junges, Joost-Pieter Katoen, Tim Quatmann & Matthias Volk (2022): *The probabilistic model checker Storm*. *International Journal on Software Tools for Technology Transfer* 24(4), pp. 589–610.
- [14] ISO (2009): *Risk Management - Vocabulary, ISO Guide 73:2009*.
- [15] Sohag Kabir & Yiannis Papadopoulos (2019): *Applications of Bayesian networks and Petri nets in safety, reliability, and risk assessments: A review*. *Safety science* 115, pp. 154–175.
- [16] Felipe Leao, Kate Revoredo & Fernanda Baiao (2019): *Extending WordNet with UFO foundational ontology*. *Journal of Web Semantics* 57, p. 100499.
- [17] Milan Lopuhaä-Zwakenberg, Carlos E Budde & Mariëlle Stoelinga (2022): *Efficient and generic algorithms for quantitative attack tree analysis*. *IEEE Transactions on Dependable and Secure Computing* 20(5), pp. 4169–4187.
- [18] Sjouke Mauw & Martijn Oostdijk (2005): *Foundations of attack trees*. In: *International Conference on Information Security and Cryptology*, Springer, pp. 186–198.

- [19] Leonardo de Moura & Sebastian Ullrich (2021): *The lean 4 theorem prover and programming language*. In: *International Conference on Automated Deduction*, Springer, pp. 625–635.
- [20] Stefano M. Nicoletti, E. Moritz Hahn, Mattia Fumagalli, Giancarlo Guizzardi & Mariëlle Stoelinga (2025): *WATCHDOG: an ontology-aWare risk AssessmentT approaCH via object-oriented DisruptiOn Graphs*. In: *International Conference on Advanced Information Systems Engineering*, Springer, pp. 314–331.
- [21] Stefano M Nicoletti, E Moritz Hahn et al. (2022): *BFL: a logic to reason about fault trees*. In: *2022 52nd Annual IEEE/IFIP DSN*, IEEE, pp. 441–452.
- [22] Stefano M Nicoletti, Milan Lopuhaä-Zwakenberg, E Moritz Hahn & Mariëlle Stoelinga (2023): *PFL: A Probabilistic Logic for Fault Trees*. In: *International Symposium on Formal Methods*, Springer, pp. 199–221.
- [23] Stefano M Nicoletti, Milan Lopuhaä-Zwakenberg, E Moritz Hahn & Mariëlle Stoelinga (2025): *ATM: a logic for quantitative security properties on attack trees*. *Software and Systems Modeling*, pp. 1–21.
- [24] Stefano M Nicoletti, Marijn Peppelman, Christina Kolb & Mariëlle Stoelinga (2023): *Model-based joint analysis of safety and security: Survey and identification of gaps*. *Computer science review* 50, p. 100597.
- [25] Stefano M Nicoletti & Mariëlle Stoelinga (2025): *BayesL: Towards a Logical Framework for Bayesian Networks*. *arXiv preprint arXiv:2506.23773*.
- [26] Ítalo Oliveira, Stefano M Nicoletti, Gal Engelberg, Mattia Fumagalli, Dan Klein & Giancarlo Guizzardi: *An ontological lens on attack trees: Toward adequacy and interoperability*. In: *Formal Ontology in Information Systems: Proceedings of the 15th International Conference (FOIS 2025)*, SAGE Publications Pvt. Ltd 1 Oliver’s Yard, 55 City Road, London, EC1Y 1SP, pp. 151–165.
- [27] Ítalo Oliveira, Stefano M Nicoletti, Mattia Fumagalli, Gal Engelberg & Giancarlo Guizzardi (2025): *Toward an ontology-based modeling for risk management*. In: *18th International Workshop on Value Modelling and Business Ontologies, VMBO 2025*.
- [28] Judea Pearl & Stuart Russell (2000): *Bayesian networks*.
- [29] Enno Ruijters & Mariëlle Stoelinga (2015): *Fault tree analysis: A survey of the state-of-the-art in modeling, analysis and tools*. *Computer science review* 15, pp. 29–62.
- [30] Tiago Prince Sales et al. (2018): *The common ontology of value and risk*. In: *Conceptual Modeling. ER 2018*, Springer, pp. 121–135.
- [31] Bahare Salmani & Joost-Pieter Katoen (2020): *Bayesian inference by symbolic model checking*. In: *International Conference on Quantitative Evaluation of Systems*, Springer, pp. 115–133.
- [32] Bruce Schneier et al. (1999): *Attack trees*. *Dr. Dobbs’s journal* 24(12), pp. 21–29.
- [33] Mariëlle Stoelinga, Christina Kolb, Stefano M Nicoletti, Carlos E Budde & Ernst Moritz Hahn (2021): *The marriage between safety and cybersecurity: still practicing*. In: *International Symposium on Model Checking Software*, Springer, pp. 3–21.
- [34] William E Vesely, Francine F Goldberg, Norman H Roberts & David F Haasl (1981): *Fault tree handbook*. Technical Report.